Ecosistema de Automatización IA Autónomo para Negocios

Documentación de Seguridad y Resiliencia

Este documento cubre el manejo de credenciales, los controles de seguridad del sistema y las medidas de resiliencia frente a fallas, con evidencia real de pruebas realizadas durante el desarrollo.

Manejo de credenciales

Credencial	Dónde vive	Exposición
Claude API Key (Anthropic)	Credential de n8n, cifrada en su almacenamiento interno	Nunca aparece en nodos, logs ni en el JSON exportado del workflow (n8n no exporta valores de credenciales)
Gmail OAuth	Credential de n8n (OAuth2), token gestionado por n8n	No requiere exponer contraseña; el token se renueva automáticamente y puede revocarse desde la cuenta de Google en cualquier momento
Notion Integration Token	Credential de n8n, cifrada	Acceso limitado a las 3 bases de datos conectadas explícitamente a la integración, no a todo el workspace

Regla operativa: ninguna credencial se hardcodea en nodos, expresiones ni código. Todas las claves viven exclusivamente en el sistema de Credentials de n8n, separado de la definición del workflow.

Principio de menor privilegio

Integración	Alcance otorgado
Gmail	Lectura de la casilla + envío de emails. No se otorgó acceso a Drive, Calendar ni otros servicios de Google.
Notion	Integración conectada únicamente a Pedidos, Catálogo de Servicios y Registro de Errores — no a todo el workspace de Notion.
Anthropic	La API key no tiene permisos administrativos sobre la cuenta; solo permite llamadas de inferencia.

Resiliencia ante fallas

El sistema fue sometido a pruebas deliberadas de falla (caminos infelices) durante el desarrollo, no solo a casos de éxito. A continuación, los mecanismos de resiliencia implementados y verificados.

Mecanismo	Cómo funciona	Verificado con
On Error: Continue using error output	Los 3 nodos que dependen de servicios externos (Claude Haiku, Claude Sonnet, Gmail) no detienen el workflow ante una falla: redirigen a una rama de manejo de error dedicada.	Prueba con credencial de Anthropic deliberadamente inválida; prueba con campo "To" de Gmail deliberadamente roto. Ambas ejecuciones completaron sin romper el flujo general.
Registro centralizado de errores	Toda falla queda registrada en la base Registro de Errores de Notion con timestamp, nodo, tipo y mensaje de error, permitiendo auditoría y seguimiento manual.	4 registros de error generados durante las pruebas, visibles en el Dashboard de Control (vista "Errores Recientes").
Anti-loop / anti-reenvío	Al marcar un pedido como "Enviado", ese registro deja de cumplir la condición del Filtro de aprobados, evitando que un trigger futuro lo reenvíe o lo reprocese.	Verificado en ejecuciones repetidas sobre el mismo pedido tras el envío: no se generaron reenvíos duplicados.
Gate humano (HITL) antes del envío	Ningún email sale sin una aprobación manual explícita, evitando el envío automático de propuestas no revisadas (incluyendo casos de datos insuficientes o ambiguos).	Caso de prueba con email de datos insuficientes: la propuesta generada quedó pendiente de aprobación y no se envió hasta la revisión manual.

Validación de tipos y comparaciones correctas

El filtro de aprobación compara el campo Estado como tipo String explícito ("is equal to", sin conversión automática de tipos), evitando falsos positivos por coerción implícita. Este punto fue además origen de un bug real detectado y corregido durante las pruebas: el campo Título de los registros de error debía forzarse a tipo string mediante concatenación de texto ("ERR-" + timestamp), ya que una expresión numérica sin convertir rompía la creación de la página en Notion.

Incidentes reales durante el desarrollo (evidencia de resiliencia)

Incidente	Causa raíz	Resolución
"Title is required to create a database page" al registrar errores	Una property "Title" duplicada dentro de la lista de Properties del nodo competía con el campo Title real de Notion (solo se permite una property de tipo título por base)	Se localizó y eliminó la property duplicada; se dejó un único campo Title con expresión de concatenación de string
Reaparición del mismo bug en producción tras el fix	El workflow se corrigió en el Editor pero no se volvió a Publicar; producción seguía ejecutando la versión anterior	Se estableció como práctica: todo fix de nodo requiere una nueva Publicación antes de considerarse resuelto
Credencial de Gmail/Anthropic quedó "rota" entre pruebas	Se rompió deliberadamente para simular camino infeliz y no se restauró de inmediato	Se estableció el protocolo: guardar la clave real fuera de n8n antes de romperla, y nunca compartir claves reales en texto plano fuera del campo de credencial
Gmail Trigger dejó de detectar emails nuevos sin mostrar error	El token OAuth2 de la credencial de Gmail venció/se revocó; el polling fallaba en silencio (ninguna ejecución quedaba registrada, ni siquiera vacía) hasta que un test manual ("Fetch Test Event") expuso el mensaje real: "The credential needs to be reconnected"	Se reconectó la cuenta de Gmail (Disconnect + nuevo login OAuth) y se dejó como práctica probar manualmente un nodo trigger cuando el polling programado no genera ninguna ejecución, en vez de asumir que el filtro está mal
El Filtro de aprobación descartaba un pedido con Estado idéntico al esperado	El valor comparado en la condición ("Aprobado por Humano") se veía idéntico al valor real del campo Estado, pero la comparación estricta de string fallaba — causa más probable: un carácter invisible (ej. espacio no separable) introducido al tipear/pegar el valor, no detectable a simple vista	Se borró y volvió a tipear el valor de comparación a mano y se re-publicó el workflow; quedó como práctica retipear a mano los valores de comparación exacta en vez de copiarlos, y no asumir que "se ve igual" significa "es igual" en un filtro de tipo string

Riesgos conocidos y mitigaciones futuras

Riesgo	Mitigación sugerida (no implementada en esta entrega)
Poll de 1 minuto genera latencia entre evento y procesamiento	Migrar a webhooks nativos de Gmail/Notion cuando estén disponibles, para procesamiento casi instantáneo
Sin límite de tasa (rate limiting) sobre emails entrantes	Agregar un control de volumen máximo de ejecuciones por hora para evitar sobrecostos ante un pico o spam
Credenciales expuestas si el JSON del workflow se comparte sin cuidado	n8n no exporta valores de credenciales en el JSON, pero se debe rotar la API key de Anthropic antes de publicar el repo (se expuso repetidamente durante pruebas de error)